



INTRODUCTION TO CARTA [CONTINUOUS ADAPTIVE RISK AND TRUST ASSESSMENT] FRAMEWORK

Digit Oktavianto
Independent Security Researcher
Meetup IT Security & Audit – 8th March 2019

Who Am I



- ❖ Information Security Consultant at MII
- ❖ DFIR Team
- ❖ Tim Hore Cyber Defense Community Indonesia
- ❖ Member Indonesia HoneyNet Project
- ❖ Member Asosiasi Cloud Computing Indonesia
- ❖ Opreker and Researcher

Introduction to CARTA Framework



CARTA Framework introduced in 2017 at Gartner Security Summit. Neil MacDonald, Eric Ahlm and Ramon Krikken introducing a new charter that will transform all areas of information security moving forward. They introduced a new strategic approach called CARTA (**Continuous Adaptive Risk and Trust Assessment**)

CARTA builds on Gartner's **Adaptive Security Architecture** and pushes enterprises to embrace a continuously adaptive approach to information security area.

Adaptive Security Architecture



Adaptive Security Architecture introduced by Sun Microsystems in 2009*. This architecture **would be able to anticipate, respond to and contain threats while reducing threat amplification, attack surface, velocity and recovery time**. It was an architectural model that imitated a biological autoimmune system at a microscopic level and ecological systems on a macroscopic level.

Biological systems **can respond to new conditions and adapt. They respond to threats dynamically using an innate, involuntary immune system response**. Ecological systems are **comprised of different components and not dependent on one single entity to survive**. They are diverse and resilient.

*<http://vancouver-issa.org/events/presentations/2009/2009-01-15/Adaptive-Security-ISSA-BC.pdf>

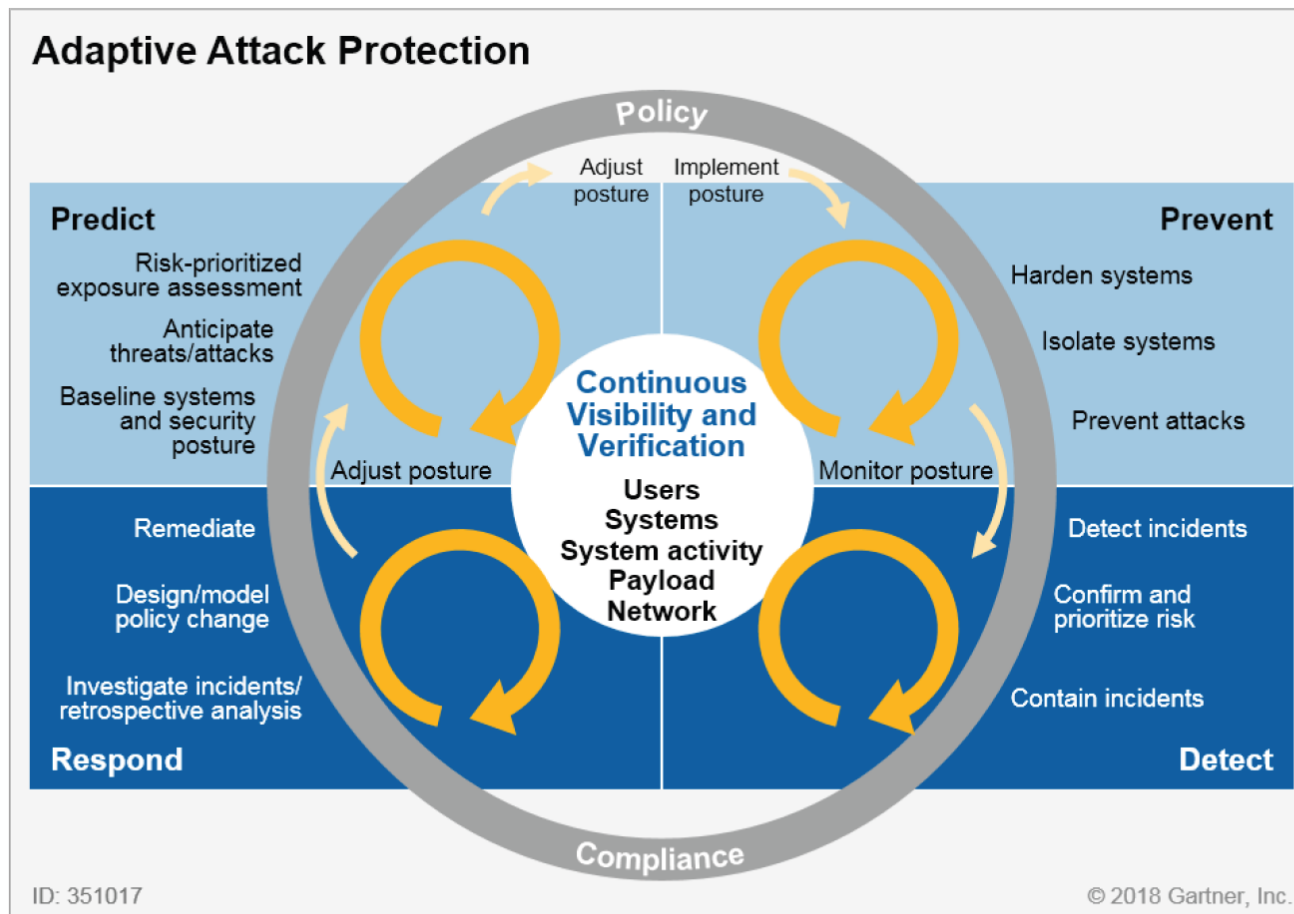
Key Point Adaptive Security Architecture



Key Point Adaptive Security Framework :

- ❖ **Reduce threat amplification** – it restricts the potential spread of a pandemic in a monoculture.
- ❖ **Shrink the attack surface** – make the target of an attack smaller
- ❖ **Decrease attack velocity** – slow the rate of attack
- ❖ **Reduce remediation time** – respond to an attack quickly
- ❖ **Facilitate the availability of data and processing resources** – prevent or contain attacks that try to limit resources
- ❖ **Promote correctness of data and the reliability of processing resources** – respond to attacks intended to compromise data or system integrity.

Adaptive Security Framework



Source: Gartner (April 2018)

Key Point Adaptive Security Architecture



- Many enterprise IT security teams spend much of their time focused on preventing a cyberattack. In doing so, they have **implemented a “incident response” mindset rather than a “continuous response”** where systems are assumed to be compromised and require continuous monitoring and remediation.
- The adaptive security architecture is a useful framework to help organisations classify existing and potential security investments to ensure that **there is a balanced approach to security investments.**
- Prevention and detection are key pillars of a traditional approach to cybersecurity. “In the digital world, however, **predicting new threats and automating routine cybersecurity responses and practices** — to free up the time of human specialists for the most complex incidents — is key to staying ahead of an expanding universe of threats and risks
- Moreover, relying only on prevent-and-detect perimeter defenses and rule-based security, such as antivirus and firewalls, becomes less effective. Therefore, the current “incident response” mindset of many organizations — which views security incidents as one-off events — must shift to a **“continuous response”**

Key Challenges and Recommendations in Designing Adaptive Security Architecture



Key Challenges

- Existing blocking and prevention capabilities are insufficient to protect against motivated, advanced attackers.
- Most organizations continue to overly invest in prevention-only strategies.
- Limited visibility in advanced attacks.
- Because enterprise systems are under continuous attack and are continuously compromised, an ad hoc approach to "incident response" is the wrong mindset.

Key Challenges and Recommendations in Designing Adaptive Security Architecture



Recommendations

- Shift from “Incident response” to “Continuous response”
- Adopt an adaptive security architecture.
- Spend less on prevention; invest in detection, response and predictive capabilities.
- Develop a security operations center that supports continuous monitoring.

Traditional Vs Modern Cyber Defense Principle



PS : Quoted from SANS SEC 511 Class – Continuous Monitoring and Security Operation (**Not an Endorsement :D**)

- **Traditional Cyber Defense :**
 - Traditional Cyber Defense **does not simply mean** an old or outdated model
 - Traditional Cyber Defense == Prevention-Oriented
 - Goals that follow :
 - Keep the bad guys out
 - Keep malware from running
 - Block the badness
 - Example technology : firewall, antimalware, IPS,
- **Verify this statement :**
 - $P / (P+D) * 100\% = \% \text{ Preventive Technology}$
 - $D / (P+D) * 100\% = \% \text{ Detection Technology}$

Traditional Vs Modern Cyber Defense Principle



- **Traditional Cyber Defense (Cont'd..) :**
 - Perimeter Focused (This is because security has predominantly focused on attacks from outside)
 - Device Driven Security
 - Keep Security Device Running
 - Provide a routine PM / CM
 - Basic configuration updates

Traditional Vs Modern Cyber Defense Principle



- **Modern Cyber Defense :**
 - Presumptions of Compromise
 - Your preventive technology will eventually fail or have already failed without your knowledge
 - Assets will be compromised
 - Accept that any asset can and will be compromised
 - Starting with assumptions, detection and response capabilities will suddenly become drastically more important
 - Detection Oriented
 - Robust detection is **very hard**
 - Employ **hardcore detective** capability technology

Traditional Vs Modern Cyber Defense Principle



- **Modern Cyber Defense (Cont'd..) :**
 - Proactive Detection : Threat Hunting
 - Threat hunting start fro hypothesis where is the compromised asset
 - Proactive instead of reactive
 - Needs extensive knowledge and experience in human resource with cross security domain
 - **Buzzword** for Security Technology lately
 - Response Driven
 - IR Plan? Forensic Team?
 - **Detect, Deter, Respond**
 - How long from Response Security Incident to Take Actionable Activity Within your Organization?

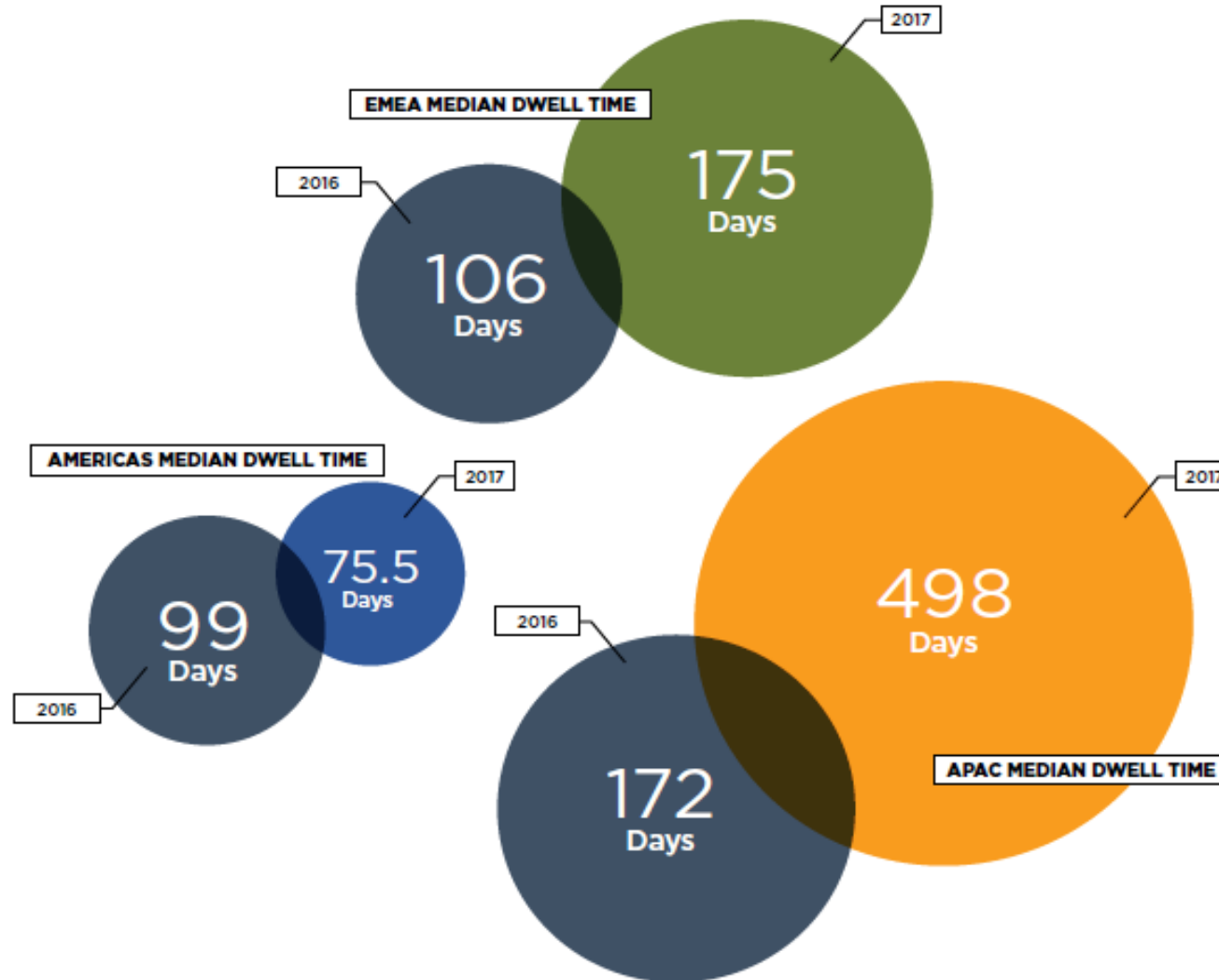
Traditional Vs Modern Cyber Defense Principle



- **Modern Cyber Defense (Cont'd..) :**
 - Post Exploitation Focused



Dwell Time of Cyber Security Attack



Traditional Vs Modern Cyber Defense Principle



- Response Driven
 - IR Plan? Forensic Team?
 - **Detect, Deter, Respond**
 - How long from Response Security Incident to Take Actionable Activity Within your Organization?
- Risk Informed
 - Risk Management Team Involved of any kind of Security Incident
 - Focus on high impact vuln and high likelihood threats
 - 20 Critical Security Control as part of Risk Assessment

Concept of CARTA Framework



The twin concepts behind CARTA are that [2]:

1. “All systems and devices must be considered potentially compromised and their behaviour continuously assessed for risk and trust.”
2. “Users (and other entities), even once authenticated, are given just enough trust to complete the action being requested, and their behaviour are continuously verified and assessed for risk.”

Gartner’s continuous adaptive risk and trust assessment (CARTA) approach is how we evolve security from rigid and reactive to flexible and proactive

7 CARTA Imperatives



Seven CARTA Imperatives

- 1 Replace one-time security gates with context-aware, adaptive and programmable security platforms.
- 2 Continuously discover, monitor, assess and prioritize risk — proactively and reactively.
- 3 Perform risk and trust assessments early in digital business initiatives.
- 4 Instrument infrastructure for comprehensive, full-stack risk visibility, including sensitive data handling.
- 5 Use analytics, AI, automation, and orchestration to speed the time to detect and respond and to scale.
- 6 Architect security as an integrated, adaptive programmable system, not silos.
- 7 Put continuous data-driven risk decision making and risk ownership into BUs and product owners.

ID: 351017

© 2018 Gartner, Inc.

Source: Gartner (April 2018)

SUMMARY



The CARTA strategic approach is defined in key concept, include :

- Decisions must continuously adapt. Security responses must continuously adapt. Risk and Trust must continuously adapt.
- Initial block/allow security assessments for access and protection leave enterprises exposed to zero-day and targeted attacks, credential theft, and insider threats.
- Trust and risk must be dynamic, not static, and assessed continuously as interactions take place and additional context becomes available.
- Digital business outcomes can only be optimized when digital trust is adaptively managed as a set of fine grained measures of confidence with multidimensional risk and response attributes.